Introduction to Cryptography

Lecture 4: Security Attacks, Security Services and Security Mechanisms

Dr. Siddhant Thapliyal

Department of Computer Science and Engineering
Graphic Era (Deemed to be University), Dehradun

OSI Security Architecture

The X.800 Security Architecture organizes network security into three fundamental concepts:



Security Attack

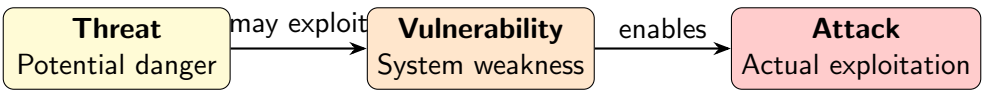
Definition

A security attack is any action that compromises the security of information or violates the security policy of a system.

Examples include:

- Unauthorized disclosure of information
- Unauthorized modification of data
- Impersonation of a legitimate user
- Reuse of captured authentication messages
- Disruption of communication services

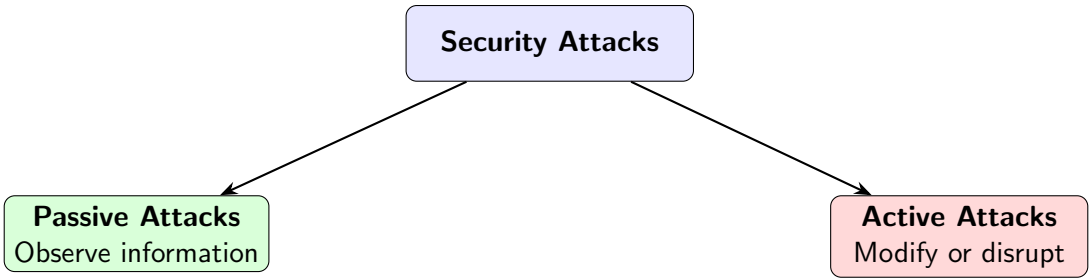
Threat, Vulnerability, and Attack



Example

A weak password is a vulnerability. The possibility of account compromise is a threat. Guessing or stealing the password is an attack.

Classification of Security Attacks



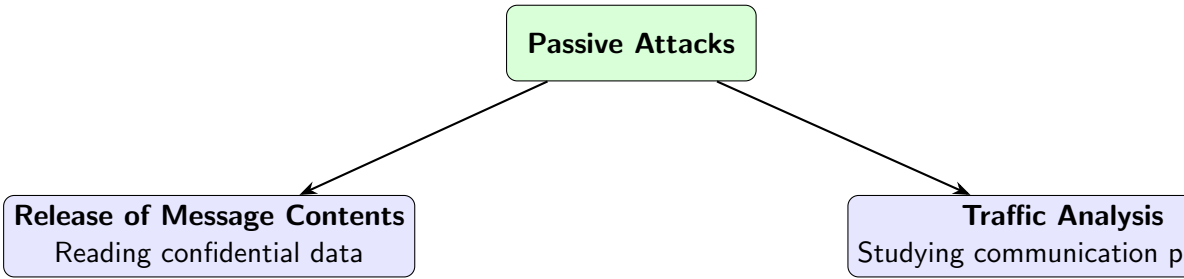
Passive Attacks

Definition

A passive attack attempts to learn or make use of information from a system without affecting system resources.

- The attacker observes communication.
- The attacker does not change transmitted data.
- Normal communication continues.
- The sender and receiver may remain unaware.
- Passive attacks primarily threaten confidentiality.

Types of Passive Attacks



Release of Message Contents

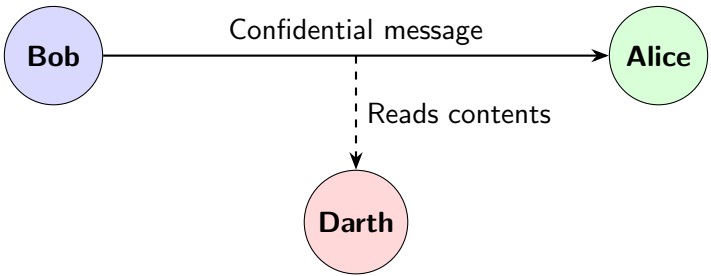
The attacker obtains the actual contents of a communication.

- Reading an email
- Listening to a telephone conversation
- Capturing login credentials
- Reading a transferred file
- Intercepting banking information

Primary Defence

Encryption protects the meaning of the message even if it is intercepted.

Release of Message Contents: Illustration



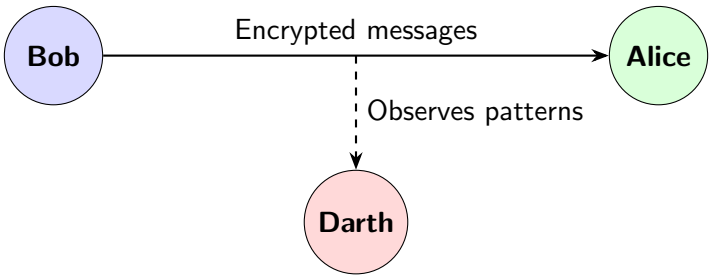
The attacker secretly reads the message sent from Bob to Alice.

Traffic Analysis

Traffic analysis occurs when an attacker studies communication patterns, even when the data is encrypted.
The attacker may determine:

- Identity of communicating parties
- Source and destination locations
- Frequency of communication
- Length of messages
- Timing of messages
- Volume of transmitted data

Traffic Analysis: Illustration



Encryption hides the content but may not hide communication patterns.

Handling Passive Attacks

Passive attacks are difficult to detect because they do not alter data.
Therefore, the emphasis is on prevention through:

- Encryption
- Traffic padding
- Secure communication channels
- Anonymous routing
- Physical protection of communication links

Key Point

For passive attacks, prevention is generally more practical than detection.

Active Attacks

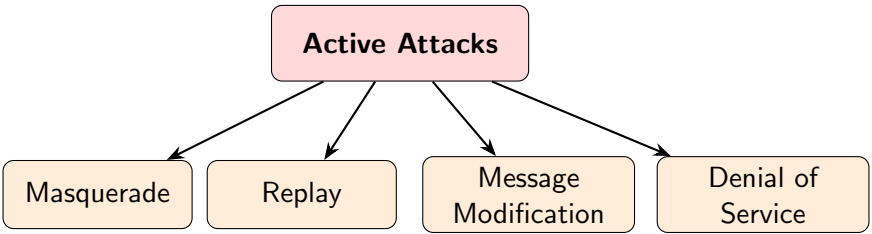
Definition

An active attack attempts to alter system resources, modify a data stream, create a false stream, or affect system operation.

Active attacks may:

- Change message contents
- Insert false messages
- Reuse captured messages
- Impersonate legitimate entities
- Disrupt services

Types of Active Attacks



Masquerade

Definition

A masquerade attack occurs when one entity pretends to be another entity.

- Uses stolen or forged credentials
- Impersonates an authorized user
- May obtain unauthorized privileges
- Often accompanies replay or credential theft

Example

An attacker uses a faculty member's credentials to modify student marks.

Replay Attack

Definition

Replay involves the capture of a valid data unit and its later retransmission to produce an unauthorized effect.

- A valid message is captured.
- The attacker stores the message.
- The same message is retransmitted later.
- The receiver may accept it as fresh.

Example

A valid online payment instruction is captured and submitted again.

Preventing Replay Attacks

Replay attacks can be countered using:

- Random nonces
- Timestamps
- Sequence numbers
- Challenge-response protocols
- Session identifiers
- Short-lived authentication tokens

Freshness

The receiver must verify that a message is new and has not already been used.

Modification of Messages

A message modification attack occurs when an attacker:

- Changes part of a legitimate message
- Inserts additional data
- Deletes information
- Delays a message
- Reorders messages

Original Message

Allow John Smith to read the confidential accounts file.

Modified Message

Allow Fred Brown to read the confidential accounts file.

Denial of Service

Definition

A denial-of-service attack prevents or inhibits the normal use or management of communication facilities and system resources.

Examples include:

- Flooding a server with requests
- Disabling a network device
- Blocking messages to a destination
- Exhausting CPU, memory, or bandwidth
- Crashing a service using malformed input

Passive vs Active Attacks

Feature	**Passive Attack**	**Active Attack**
Main objective	Obtain information	Modify or disrupt resources
Data modification	No	Yes
Detection	Very difficult	Usually possible
Main goal affected	Confidentiality	Integrity, authenticity, availability
Primary response	Prevention	Detection and recovery

Security Service

Definition

A security service is a processing or communication service that provides a specific type of protection to system resources or data transfers.

Security services:

- Implement security policies.
- Counter one or more attacks.
- Are implemented using security mechanisms.
- Protect communication and system resources.

Categories of Security Services

X.800 defines five major categories of security services:

1. Authentication
2. Access control
3. Data confidentiality
4. Data integrity
5. Nonrepudiation

Availability is also commonly treated as an important security service.

Authentication Service

Purpose

Authentication provides assurance that a communicating entity or the source of received data is genuine.

Two authentication services are defined:

1. Peer-entity authentication
2. Data-origin authentication

Peer-Entity Authentication

Definition

Peer-entity authentication verifies the identity of an entity participating in a logical connection.

It may be performed:

- During connection establishment
- At selected times during data transfer

It helps protect against:

- Masquerade
- Unauthorized replay of a previous connection

Data-Origin Authentication

Definition

Data-origin authentication verifies that the source of a received data unit is the entity that it claims to be.

- Commonly used for connectionless communication
- Useful in electronic mail
- Confirms the claimed source of a message
- Does not by itself prevent duplication
- Does not by itself prevent message modification

Peer-Entity vs Data-Origin Authentication

Feature	**Peer-Entity**	**Data-Origin**
Purpose	Verify communicating entity	Verify source of data
Communication type	Connection-oriented	Usually connectionless
Example	Client-server login	Verification of email sender
Protection	Masquerade and replay	False source identity

Access Control Service

Definition

Access control prevents unauthorized use of a resource.

It determines:

- Who may access a resource
- Under what conditions access is permitted
- What operations may be performed
- When access may occur

Example

A student may view marks, but only an authorized faculty member may update them.

Data Confidentiality Services

- **Connection confidentiality:** Protects all user data transmitted over a connection.
- **Connectionless confidentiality:** Protects all user data in a single data block.
- **Selective-field confidentiality:** Protects selected fields within a message.
- **Traffic-flow confidentiality:** Protects information derived from traffic patterns.

Data Integrity Service

Definition

Data integrity ensures that received data is exactly as sent by an authorized entity.

Integrity protects against:

- Modification
- Insertion
- Deletion
- Duplication
- Reordering
- Replay

Types of Data Integrity Services

- **Connection integrity with recovery:** Detects integrity violations and attempts recovery.
- **Connection integrity without recovery:** Detects violations but does not recover automatically.
- **Selective-field connection integrity:** Protects selected fields in connection-oriented communication.
- **Connectionless integrity:** Protects a single independent data block.
- **Selective-field connectionless integrity:** Protects selected fields in a single data block.

Nonrepudiation

Definition

Nonrepudiation prevents an entity involved in communication from denying its participation.

Two forms are:

- **Nonrepudiation of origin:** Provides proof that the specified sender sent the message.
- **Nonrepudiation of destination:** Provides proof that the specified receiver received the message.

Example

A digital signature can provide evidence that a sender approved a document.

Availability Service

Definition

Availability ensures that a system or resource is accessible and usable on demand by an authorized entity.

Availability depends on:

- Proper resource management
- Access control
- Redundant systems
- Backup and recovery
- Protection against denial-of-service attacks

Security Mechanism

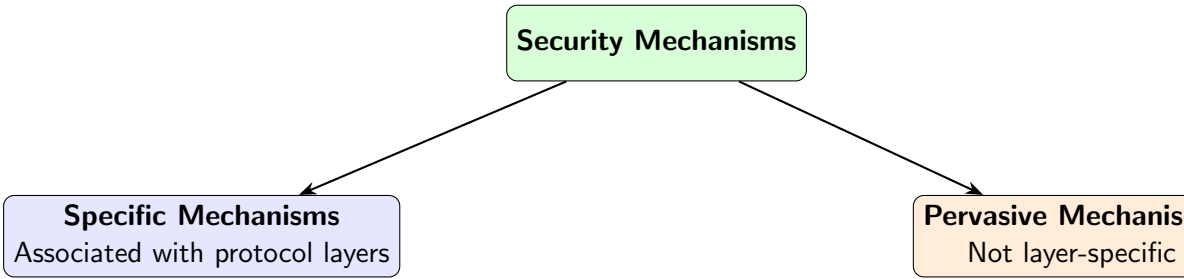
Definition

A security mechanism is a process or device designed to detect, prevent, or recover from a security attack.

X.800 divides mechanisms into:

1. Specific security mechanisms
2. Pervasive security mechanisms

Classification of Security Mechanisms



Specific Security Mechanisms

Specific security mechanisms include:

1. Encipherment
2. Digital signature
3. Access control
4. Data integrity
5. Authentication exchange
6. Traffic padding
7. Routing control
8. Notarization

Encipherment

Definition

Encipherment uses mathematical algorithms to transform data into a form that is not readily intelligible.

$$\text{Plaintext} \xrightarrow[\text{Key}]{\text{Encryption}} \text{Ciphertext} \xrightarrow[\text{Key}]{\text{Decryption}} \text{Plaintext}$$

- Primarily supports confidentiality
- Requires an encryption algorithm
- Usually requires one or more keys

Digital Signature

Definition

A digital signature is data appended to, or a cryptographic transformation of, a data unit that provides evidence of origin and integrity.

Digital signatures support:

- Source authentication
- Data integrity
- Nonrepudiation
- Protection against forgery

Authentication Exchange

Definition

Authentication exchange is a mechanism that verifies an entity's identity through the exchange of authentication information.

Examples include:

- Password-based login
- One-time password
- Challenge-response protocol
- Digital certificate exchange
- Biometric authentication

Traffic Padding

Definition

Traffic padding inserts additional bits or dummy messages into gaps in a data stream.

Purpose:

- Hide message frequency
- Hide message length
- Make traffic patterns less predictable
- Reduce the effectiveness of traffic analysis

Observation

Traffic padding adds communication overhead.

Routing Control

Definition

Routing control allows the selection of secure communication routes and the changing of routes when a security breach is suspected.

Applications include:

- Avoiding insecure networks
- Selecting trusted communication paths
- Rerouting communication after an attack
- Protecting highly sensitive transmissions

Notarization

Definition

Notarization uses a trusted third party to assure specific properties of a data exchange.

A trusted third party may verify:

- Time of submission
- Identity of participants
- Delivery of a message
- Existence of a document
- Completion of a transaction

Pervasive Security Mechanisms

Pervasive mechanisms are not specific to a particular protocol layer or security service. They include:

1. Trusted functionality
2. Security labels
3. Event detection
4. Security audit trail
5. Security recovery

Trusted Functionality and Security Labels

Trusted Functionality

System functions that are considered correct according to established security criteria or policy.

Security Label

A marking associated with a resource that identifies its security attributes.

Examples

Public, Internal, Confidential, Secret, and Top Secret.

Event Detection

Definition

Event detection identifies security-relevant events occurring within a system or network.

Examples include:

- Multiple failed login attempts
- Unauthorized file modification
- Unusual network traffic
- Malware execution
- Privilege escalation
- Abnormal resource consumption

Security Audit Trail

Definition

A security audit trail is a collection of records used to examine system activities and security events.

Audit records may include:

- User identity
- Date and time
- Resource accessed
- Operation performed
- Source IP address
- Success or failure status

Security Recovery

Definition

Security recovery responds to detected security events and performs actions to restore the system to a secure state.

Recovery actions may include:

- Terminating malicious sessions
- Restoring data from backup
- Isolating compromised systems
- Revoking credentials
- Changing encryption keys
- Reconfiguring firewalls

Services and Supporting Mechanisms

Security Service	**Common Supporting Mechanisms**
Peer-entity authentication	Encipherment, digital signature, authentication exchange
Data-origin authentication	Encipherment, digital signature
Access control	Access-control mechanisms
Data confidentiality	Encipherment, routing control
Traffic-flow confidentiality	Encipherment, traffic padding, routing control
Data integrity	Encipherment, digital signature, data-integrity mechanisms
Nonrepudiation	Digital signature, data integrity, notarization
Availability	Access control, authentication exchange, recovery mechanisms

Attack–Service–Mechanism Mapping

Attack	Required Service	Possible Mechanism
Release of message contents	Data confidentiality	Encipherment
Traffic analysis	Traffic-flow confidentiality	Traffic padding and routing control
Masquerade	Authentication	Authentication exchange and digital signature
Replay	Authentication and integrity	Nonce, timestamp, sequence number
Message modification	Data integrity	Hash, MAC, digital signature
Denial of service	Availability	Access control, filtering, recovery

University ERP Example

Requirement	Security Service	Mechanism
Verify faculty identity	Authentication	Password, OTP, certificate
Restrict grade modification	Access control	Role-based permissions
Protect grade records	Confidentiality	Encryption
Detect altered marks	Integrity	Hash or digital signature
Trace all changes	Accountability	Audit trail
Keep portal operational	Availability	Redundancy and recovery

Online Banking Example

Consider an online banking transaction:

- Encryption protects account and transaction details.
- Authentication verifies the customer and bank server.
- Access control limits available banking operations.
- Integrity mechanisms prevent transaction modification.
- Digital signatures may support nonrepudiation.
- Timestamps and nonces prevent replay.
- Audit logs record transaction activities.
- Recovery mechanisms restore services after failure.

Class Activity

For each scenario, identify:

1. The attack
2. The required security service
3. A suitable security mechanism

- An attacker reads an unencrypted email.
- A captured payment request is retransmitted.
- A student changes marks in the ERP.
- A server is flooded with requests.
- An attacker logs in using a teacher's credentials.

Class Activity Answers

Scenario	Attack	Service	Mechanism
Reading email	Message disclosure	Confidentiality	Encryption
Resending payment	Replay	Authentication and integrity	Nonce or timestamp
Changing marks	Message modification	Integrity and access control	MAC, audit log, RBAC
Flooding server	Denial of service	Availability	Filtering and redundancy
Using teacher credentials	Masquerade	Authentication	MFA and certificates

Quick Quiz

1. What are the two major categories of security attacks?
2. Name the two passive attacks.
3. Name the four active attacks.
4. What is the difference between a service and a mechanism?
5. Name the five security service categories defined in X.800.
6. Which mechanism counters traffic analysis?
7. Which service prevents a sender from denying a message?
8. What is the purpose of a security audit trail?

References

- William Stallings, *Cryptography and Network Security: Principles and Practice*.
- William Stallings and Lawrie Brown, *Computer Security: Principles and Practice*.
- ITU-T Recommendation X.800, *Security Architecture for Open Systems Interconnection*.
- RFC 2828, *Internet Security Glossary*.

Thank You

Questions and Discussion